CRISC Domain B – 100 Exam-Style Questions (Part 2)

IT Risk Assessment – Fresh Scenarios (Answer on the Next Slide)

CRISC Mastery Series

October 21, 2026

Instructions

How to Use This Deck

Think like a risk practitioner: business objectives first, owners decide, assess before acting. Read for BEST, FIRST and MOST. Answer on the slide after each question.

Outline

1. Risk Identification
2. Risk Analysis
3. Risk Evaluation and Appetite
4. Risk Response
5. Controls
6. Monitoring and Reporting
7. BIA, Recovery and Third Parties
8. Governance and Risk Culture

Q1: Strategic Alignment

Question

A risk practitioner is asked to help define the IT risk universe for the year. What should they do FIRST?

- **A** List every known technical vulnerability
- **B** Obtain the enterprise's strategic objectives and business plans
- **C** Benchmark against peers
- **D** Issue a risk survey to all staff

Q1: Explanation

Correct Answer: B

- The risk universe must support enterprise objectives
- Strategy defines what matters and what does not
- Peer benchmarks and surveys are supporting inputs, not the starting point
- Vulnerability lists are tactical, not strategic

Critical Trap

Start from enterprise strategy, not technology.

Q2: Risk Appetite Input

Question

Which input is MOST important to the risk practitioner when scoping the annual IT risk assessment?

- **A** The number of outstanding tickets
- **B** The IT budget
- **C** The enterprise risk appetite and prior risk profile
- **D** The current technology stack

Q2: Explanation

Correct Answer: C

- Appetite frames acceptable exposure
- The risk profile shows where you stand
- Tickets and stack are operational context, not scope drivers

Critical Trap

Scope should reflect appetite and profile.

Q3: Business Process First

Question

When identifying IT risks for a new service, the BEST starting point is:

- (A) The servers hosting the service
- (B) The network diagrams
- (C) The underlying codebase
- (D) The business process the service supports and its objectives

Q3: Explanation

Correct Answer: D

- Risk is about the effect on the business process
- Technology is the delivery mechanism
- Process objectives anchor relevance

Critical Trap

Understand the process before the plumbing.

Q4: Third-Party Data

Question

The risk practitioner needs to identify risks from a new SaaS provider handling customer data. What should be requested FIRST?

- A. A copy of the vendor's marketing brochure
- B. The vendor's pricing list
- C. The vendor's assurance report and data flow information
- D. The vendor's org chart

Q4: Explanation

Correct Answer: C

- Assurance reports show control posture
- Data flows show scope and location
- Marketing and pricing do not address risk

Critical Trap

Ask for assurance and data flow, not sales material.

Q5: Change in Environment

Question

A new market expansion introduces new regulatory requirements. What should the risk practitioner do FIRST?

- A. Hire local staff
- B. Determine applicability and conduct a focused risk assessment
- C. Launch immediately and assess later
- D. Add insurance

Q5: Explanation

Correct Answer: B

- Applicability frames the exposure
- A focused assessment identifies gaps
- Launching first increases exposure

Critical Trap

Assess before you expand.

Q6: Scenario Source

Question

Which source BEST provides realistic risk scenarios for a mature organization?

- A. Anonymous suggestions only
- B. Generic industry checklists
- C. Lessons from past incidents plus intelligence on emerging threats
- D. The newest vendor whitepaper

Q6: Explanation

Correct Answer: C

- Past incidents reveal real failure modes
- Emerging threat intelligence anticipates new risks
- Checklists and whitepapers are supporting material

Critical Trap

Combine experience with forward-looking intelligence.

Q7: Loss Event Categories

Question

When building a loss event taxonomy, the practitioner should focus primarily on:

- **A** Vendor names
- **B** Loss categories that matter to the business such as confidentiality, integrity, availability and compliance
- **C** Individual system owners
- **D** IT budget lines

Q7: Explanation

Correct Answer: B

- CIA plus compliance covers major impact types
- A consistent taxonomy supports aggregation
- Names and budgets are irrelevant to categorization

Critical Trap

Taxonomy must reflect business impact types.

Q8: Interview Bias

Question

An interviewer asks leading questions about past incidents. What is the MAIN risk?

- (A) The interview takes too long
- (B) Responses may be biased toward the interviewer's expectations
- (C) The interviewee may refuse to answer
- (D) The notes are hard to read

Q8: Explanation

Correct Answer: B

- Leading questions steer answers
- Bias reduces reliability
- Use neutral, open questions and structure

Critical Trap

Neutral framing improves reliability.

Q9: Risk Owner Identification

Question

During risk identification, what is MOST helpful in defining who will own a risk?

- **A** The IT department head
- **B** The external auditor
- **C** The process owner who is accountable for the affected business outcome
- **D** The risk practitioner

Q9: Explanation

Correct Answer: C

- Ownership belongs to the person accountable for the outcome
- Process owners have the authority to act
- Practitioners and auditors advise

Critical Trap

Ownership follows the business outcome.

Q10: Risk Workshop Output

Question

Which output is MOST valuable from a risk identification workshop?

- A. A long list of vulnerabilities
- B. A signed project charter
- C. Agreed risk statements with owners and business context
- D. A list of control costs

Q10: Explanation

Correct Answer: C

- Risk statements link cause, event, and business impact
- Owners make them actionable
- Vulnerability lists are technical inputs

Critical Trap

Risk statements with owners are actionable.

Q11: Asset Criticality

Question

When prioritizing asset-level risk identification, which asset should be reviewed first?

- (A) The asset with the longest installed lifespan
- (B) The asset with the highest business process criticality
- (C) The newest asset
- (D) The asset with the most users

Q11: Explanation

Correct Answer: B

- Criticality reflects business consequence
- Older and newer assets come next based on criticality
- User count alone is not impact

Critical Trap

Criticality first, technology second.

Q12: Data Classification

Question

What is the PRIMARY reason to involve data classification in risk identification?

- **A** To reduce storage costs
- **B** To determine which data needs protection and how much
- **C** To make audits quicker
- **D** To comply with HR policy

Q12: Explanation

Correct Answer: B

- Classification drives control intensity
- Higher sensitivity means higher exposure
- Audits and costs are secondary effects

Critical Trap

Classification sets the protection bar.

Q13: Shadow AI

Question

Employees use public generative AI tools with sensitive data. What should the practitioner do FIRST?

- **A** Block all AI use
- **B** Assess the data being exposed and the business impact
- **C** Publicly discipline the users
- **D** Accept the risk

Q13: Explanation

Correct Answer: B

- Exposure type and volume determine severity
- Blocking may disrupt legitimate needs
- Acceptance requires assessment and authority

Critical Trap

Assess the exposure before reacting.

Q14: Process Changes

Question

A core process is being redesigned. Why does the risk practitioner need to reassess risk?

- A. To add more meetings
- B. Because process changes can introduce new risks and retire old ones
- C. Because policies require a new form
- D. Because IT requested it

Q14: Explanation

Correct Answer: B

- Changed processes change risk drivers
- New risks can emerge from design choices
- Old risks may be removed or replaced

Critical Trap

Redesign changes the risk landscape.

Q15: External Threat Landscape

Question

Which external input MOST influences risk identification for internet-facing services?

- A. Peer benchmarking surveys
- B. Current threat intelligence and vulnerability disclosures relevant to the service
- C. Internal HR hiring plans
- D. Historic marketing reports

Q15: Explanation

Correct Answer: B

- Threat intelligence reflects current attacker behavior
- Disclosures expose technical exposure
- Peer and HR inputs are not technical threat data

Critical Trap

Use current threat data for internet-facing risk.

Q16: Confidence Interval

Question

A quantitative analysis yields $1.2M with a 90% confidence interval of $400K–$2.0M. What does this mean?

- A. The risk is exactly $1.2M
- B. There is a 90% chance the true loss is between $400K and $2.0M
- C. The analysis is invalid
- D. The loss will not exceed $2.0M

Q16: Explanation

Correct Answer: B

- Confidence intervals reflect uncertainty
- The point estimate is not exact
- Wide ranges signal high uncertainty

Critical Trap

Report the range, not just the point.

Q17: Probability Distribution

Question

Which distribution is MOST appropriate for modeling the number of independent incidents in a period?

- A Uniform
- B Poisson
- C Normal
- D Deterministic

Q17: Explanation

Correct Answer: B

- Poisson models counts of independent events
- Uniform assumes equal likelihood
- Normal suits continuous measures
- Deterministic ignores uncertainty

Critical Trap

Choose the model that matches the data.

Q18: Monte Carlo

Question

Monte Carlo simulation is MOST useful when:

- **A** Only one outcome is possible
- **B** There are many interacting uncertain variables
- **C** The data is fully known
- **D** No computation tools are available

Q18: Explanation

Correct Answer: B

- Simulation captures interactions of uncertainties
- Single-outcome and fully known cases do not need it
- Computation tools are required

Critical Trap

Simulate when uncertainty is complex.

Q19: Data Normalization

Question

Two business units report losses in different units and currencies. What should the analyst do FIRST?

- A. Average the raw numbers
- B. Ignore the smaller unit
- C. Normalize units and currency to enable comparison
- D. Use only the larger unit

Q19: Explanation

Correct Answer: C

- Mixed units produce invalid comparisons
- Normalization enables aggregation
- Ignoring data biases results

Critical Trap

Normalize before you compare.

Q20: Subject Matter Experts

Question

Which situation reduces the value of subject matter expert judgment?

- A. Experts are drawn from multiple functions
- B. Experts provide documented rationale
- C. Experts are interviewed independently
- D. Experts share a single worldview and are not diverse

Q20: Explanation

Correct Answer: D

- Diverse perspectives reduce blind spots
- Independent inputs reduce groupthink
- Documented rationale improves auditability
- Homogeneous experts amplify bias

Critical Trap

Diversity beats sameness in judgment.

Q21: Benchmarking Limits

Question

Benchmarking with peer breach data should be used primarily to:

- **A** Replace internal assessment
- **B** Inform context, not to substitute for internal analysis
- **C** Set the final risk score
- **D** Avoid collecting internal data

Q21: Explanation

Correct Answer: B

- Peer data may not fit your environment
- Internal data reflects your controls and threats
- Benchmarks inform, not replace

Critical Trap

Benchmarks inform; they do not decide.

Q22: Risk Score Aggregation

Question

The enterprise risk profile contains many small IT risks. What is the MOST likely mistake in aggregation?

- (A) Underestimating correlated exposure
- (B) Using a single scoring scale
- (C) Documenting all risks
- (D) Involving business owners

Q22: Explanation

Correct Answer: A

- Related risks compound beyond individual ratings
- Correlated causes increase total exposure
- Documentation and participation are good practices

Critical Trap

Watch correlation when aggregating.

Q23: Risk Sensitivity

Question

A small change in probability assumption changes the rating from Medium to High. What does this indicate?

- (A) The rating is stable
- (B) The analysis is highly sensitive to that assumption and should be validated
- (C) The risk should be ignored
- (D) The probability is wrong

Q23: Explanation

Correct Answer: B

- Sensitivity signals fragility of results
- Validate the assumption before acting
- Ignoring the signal leads to misallocation

Critical Trap

Test sensitive assumptions before decisions.

Q24: ALE Trap

Question

An asset is worth $1M, the exposure factor is 20%, and ARO is 3. What is ALE?

- (A) $60K
- (B) $2.4M
- (C) $200K
- (D) $600K

Q24: Explanation

Correct Answer: D

- SLE $= 1M \times 0.2 = \$200K$
- ALE $= 200K \times 3 = \$600K$
- \$200K is only SLE

Critical Trap

ALE is SLE multiplied by ARO.

Q25: Expected Versus Extreme

Question

The expected value of a risk is low but the worst-case outcome is severe. What should the risk manager present?

- A. Only the expected value
- B. Only the worst case
- C. Both expected value and worst case, with a recommendation
- D. Neither, to avoid confusion

Q25: Explanation

Correct Answer: C

- Decisions need a full picture
- Expected value guides normal planning
- Worst case informs contingency and appetite

Critical Trap

Present both expected and worst case.

Q26: Model Assumptions

Question

Before approving a risk analysis, leadership asks about assumptions. Why is this important?

- (A) To increase the length of the report
- (B) To test whether the conclusions hold if assumptions change
- (C) To reduce the budget
- (D) To avoid the risk

Q26: Explanation

Correct Answer: B

- Assumptions shape results
- Leadership needs to judge reliability
- Documenting assumptions supports governance

Critical Trap

Assumptions drive conclusions.

Q27: Cluster of Risks

Question

You discover ten risks tied to a single outdated platform. What is the BEST analytical view?

- (A) Treat them as independent
- (B) Ignore the platform
- (C) Look at them as a cluster and assess platform-level exposure
- (D) Remove the lowest-rated ones

Q27: Explanation

Correct Answer: C

- Common causes create correlated risk
- A platform-level view reveals total exposure
- Independence assumptions understate total risk

Critical Trap

Common causes mean combined exposure.

Q28: Data Age Impact

Question

Threat intelligence is fresh, but internal control data is two years old. Which combination is BEST for the analysis?

- **A** Fresh external threat data combined with refreshed internal control data
- **B** Fresh external data only
- **C** Old internal data only
- **D** Neither

Q28: Explanation

Correct Answer: A

- Fresh external data is current risk
- Stale internal data misrepresents controls
- Both must be current for reliable results

Critical Trap

Refresh internal data before using it.

Q29: Risk Register Aggregate

Question

The number of high-rated IT risks in the register has doubled in one quarter. What is the FIRST interpretation to verify?

- (A) The business is definitely more exposed
- (B) A change in scoring methodology or assessment quality
- (C) The controls stopped working
- (D) The register is wrong

Q29: Explanation

Correct Answer: B

- Methodology changes drive rating shifts
- Verify before concluding exposure increased
- Controls failure would be a specific finding

Critical Trap

Check methodology before concluding trend.

Q30: Risk Rating Consistency

Question

Two locations use the same methodology but differ in rating severity. What is the BEST remedy?

A. Standardized calibration workshops with real examples
B. Report both ratings
C. Average the ratings
D. Use only the higher rating

Q30: Explanation

Correct Answer: A

- Calibration aligns interpretation
- Examples anchor scoring
- Averages and higher-only hide inconsistency

Critical Trap

Calibrate with examples.

Q31: Appetite Translation

Question

The board expresses appetite as protecting brand reputation. What should the practitioner do NEXT?

- A. Ignore the statement
- B. Translate the appetite into measurable thresholds for IT risk
- C. Buy insurance
- D. Freeze the risk register

Q31: Explanation

Correct Answer: B

- Appetite must be operationalized
- Measurable thresholds enable comparison
- Protection actions follow thresholds

Critical Trap

Translate appetite into measurable thresholds.

Q32: Risk Owner Escalation

Question

The risk owner wants to accept a risk well above appetite. What should the practitioner do?

- **A** Accept it, the owner is accountable
- **B** Escalate according to governance for higher authority
- **C** Reduce the rating
- **D** Delete the risk entry

Q32: Explanation

Correct Answer: B

- Accepting above appetite requires higher authority
- The practitioner must follow escalation policy
- Ratings must not be manipulated

Critical Trap

Acceptance above appetite is not the owner's call.

Q33: Risk Tolerance Example

Question

Which is the BEST example of risk tolerance?

- (A) Loss of up to 3 hours of transaction data before escalating
- (B) Zero incidents allowed
- (C) No data loss ever
- (D) Unbounded loss

Q33: Explanation

Correct Answer: A

- Tolerance is a defined acceptable variation
- Zero and unbounded are not realistic thresholds
- Specific measure supports monitoring

Critical Trap

Tolerance is a defined, measurable variation.

Q34: Post-Treatment Above Appetite

Question

Residual risk after the planned controls is still above appetite. What is the BEST course?

- A Close the risk
- B Escalate for additional treatment or formal acceptance
- C Lower the rating
- D Ignore it

Q34: Explanation

Correct Answer: B

- Treatment or acceptance must be decided
- The owner or higher authority decides
- Quiet closure hides exposure

Critical Trap

Above appetite needs an explicit decision.

Q35: Risk Acceptance Criteria

Question

What should accompany a formal risk acceptance?

- A. A signature only
- B. Documentation of impact, rationale, duration and approval authority
- C. A verbal note
- D. No documentation

Q35: Explanation

Correct Answer: B

- Documented rationale supports accountability
- Duration and authority must be clear
- Undocumented acceptance is indefensible

Critical Trap

Acceptance needs evidence.

Q36: Appetite Monitoring

Question

What is the PRIMARY purpose of linking KRIs to risk appetite?

- A To reduce reporting
- B To detect when exposure is approaching the acceptable threshold
- C To justify budget increases
- D To satisfy auditors

Q36: Explanation

Correct Answer: B

- Appetite is a threshold
- KRIs detect drift
- Reporting is a means, not the goal

Critical Trap

KRIs are appetite monitors.

Q37: Capacity Breach

Question

Exposure is approaching risk capacity. What should be prioritized?

- A Cost reduction
- B Immediate executive action to reduce exposure
- C Policy updates
- D Staff training

Q37: Explanation

Correct Answer: B

- Capacity is existential
- Immediate action is required
- Other measures follow

Critical Trap

Capacity signals emergency action.

Q38: Appetite Versus Mission

Question

A new business line exceeds appetite but aligns with mission. What is the BEST guidance?

- (A) Proceed without discussion
- (B) Escalate to leadership to align appetite and opportunity
- (C) Abandon the line
- (D) Ignore appetite

Q38: Explanation

Correct Answer: B

- Appetite may need adjustment
- Leadership balances mission and risk
- Silent proceeding is not governance

Critical Trap

Opportunity requires re-aligning appetite.

Q39: Inconsistent Impact

Question

The business wants to reduce impact ratings to fit the budget. What is the practitioner's BEST response?

- **A** Reduce ratings to align with budget
- **B** Present evidence and independently validated impact assessments
- **C** Leave it to IT
- **D** Approve it

Q39: Explanation

Correct Answer: B

- Impact must be based on evidence
- Independence prevents manipulation
- Approving manipulated ratings undermines governance

Critical Trap

Ratings reflect evidence, not budgets.

Q40: Accepted Risk Monitoring

Question

An accepted risk is now trending toward its tolerance limit. What should happen?

- (A) Remove the risk
- (B) Re-open the decision with the owner and consider new treatment
- (C) Ignore the trend
- (D) Cancel the KRI

Q40: Explanation

Correct Answer: B

- Acceptance is not permanent
- Trends trigger re-evaluation
- Ignoring trends misses warnings

Critical Trap

Acceptance must be re-affirmed, not assumed.

Q41: Transfer Limitations

Question

Which risk can insurance NOT transfer?

- **A** Reputational loss from a public breach
- **B** Financial cost of recovery
- **C** Legal defense costs
- **D** Regulatory fines where insurable

Q41: Explanation

Correct Answer: A

- Reputation is not insurable
- Financial and legal costs are insurable
- Some fines are insurable depending on jurisdiction

Critical Trap

Reputation cannot be transferred.

Q42: Justified Investment

Question

An annual ALE of $500K is addressed by a control costing $200K. Which statement is MOST accurate?

A. The control is not justified
B. The control may be justified pending effectiveness validation
C. The control is always unnecessary
D. No analysis is required

Q42: Explanation

Correct Answer: B

- Cost is less than the ALE
- Effectiveness must be validated
- Justification is supported but conditional

Critical Trap

Cost-benefit supports it; validate effectiveness.

Q43: Outsourcing Oversight

Question

After outsourcing a process, what oversight should continue?

- A None, the vendor is responsible
- B Monitoring of the vendor's performance and assurance evidence
- C Only annual meetings
- D Only contract renewal

Q43: Explanation

Correct Answer: B

- Outsourcing transfers tasks, not accountability
- Ongoing monitoring catches drift
- Annual meetings are not enough

Critical Trap

Monitor the vendor continuously.

Q44: Response Alignment

Question

Which response is BEST aligned with a risk appetite that tolerates minor outages but not data loss?

A. Reduce availability controls and focus on backups and integrity controls
B. Remove backups
C. Focus only on uptime marketing
D. Do nothing

Q44: Explanation

Correct Answer: A

- The appetite differentiates availability and data loss
- Integrity and backup controls address data loss
- Availability controls can be lighter

Critical Trap

Fit the control portfolio to appetite specifics.

Q45: Avoidance Decision

Question

When is avoidance the MOST appropriate response?

- (A) When the risk can be reduced to acceptable levels cheaply
- (B) When the risk cannot be treated to acceptable levels and the activity is not essential
- (C) When the risk is low
- (D) When insurance is available

Q45: Explanation

Correct Answer: B

- Avoidance stops the activity
- It suits unacceptable, inessential risks
- Other options are cheaper when viable

Critical Trap

Avoid only when the activity is truly not needed.

Q46: Preventive Example

Question

Which control is PURELY preventive?

- (A) Log monitoring
- (B) Backup restoration
- (C) Encryption at rest
- (D) Incident reporting

Q46: Explanation

Correct Answer: C

- Encryption prevents reading even if data is exposed
- Log monitoring is detective
- Backup restoration is corrective

Critical Trap

Prevention stops exposure before it matters.

Q47: Detective Timing

Question

A detective control fails silently for six months. What is the MOST likely consequence?

- A. No consequence
- B. Incidents may go undetected and their impact will grow
- C. The risk is eliminated
- D. The threat disappears

Q47: Explanation

Correct Answer: B

- Detection failure delays response
- Impact grows
- Visibility of failures is critical

Critical Trap

Detective controls fail silently.

Q48: Compensating Approval

Question

Who should approve a compensating control?

- A. The vendor
- B. The control owner only
- C. The risk owner, based on evidence that it addresses the same risk
- D. The IT helpdesk

Q48: Explanation

Correct Answer: C

- Compensating controls must reduce the same risk
- The risk owner decides whether it is sufficient
- The control owner documents operation

Critical Trap

The risk owner approves compensation.

Q49: Residual Ownership

Question

Who is accountable for residual risk after implementation?

- A The vendor
- B The project manager
- C The IT department
- D The risk owner

Q49: Explanation

Correct Answer: D

- Residual risk remains with the business owner
- The project ends, but the risk continues
- Vendors do not hold business accountability

Critical Trap

Residual risk stays with the owner.

Q50: Response Effectiveness

Question

Which test MOST reliably confirms a risk response is effective?

- **A** Reviewing the design document
- **B** A verified post-implementation review with evidence
- **C** Verbal assurance from the team
- **D** A project closure report

Q50: Explanation

Correct Answer: B

- Evidence confirms real effect
- Design reviews do not prove operation
- Verbal and closure reports may lack rigor

Critical Trap

Verify with evidence.

Q51: Documented Accept

Question

A risk owner refuses to sign the acceptance. What should the practitioner do?

- (A) Proceed as if accepted
- (B) Document the refusal and escalate
- (C) Forge the acceptance
- (D) Delete the risk

Q51: Explanation

Correct Answer: B

- Refusal indicates unresolved concerns
- Escalation is required
- Undocumented or forged acceptance is improper

Critical Trap

Refusal is a governance event.

Q52: Vendor Assurance

Question

The vendor will not share third-party assurance reports but permits an audit. What is the BEST path?

- A. Conduct the audit or accept additional compensating controls
- B. Ignore the vendor
- C. Sign anyway
- D. Skip the contract

Q52: Explanation

Correct Answer: A

- Direct audit provides assurance
- Compensating controls may be acceptable
- Skipping assurance leaves exposure unknown

Critical Trap

Audit or compensate, do not skip.

Q53: Exception Cadence

Question

A policy exception is approved for one year. What should happen at year-end?

- (A) Renew automatically
- (B) Validate the need and controls, then decide
- (C) Delete the exception
- (D) Escalate to the board

Q53: Explanation

Correct Answer: B

- Circumstances may have changed
- Validation prevents stale exceptions
- Automatic renewal is not governance

Critical Trap

Exceptions must be re-validated.

Q54: Ineffective Response

Question

A control is not delivering the expected risk reduction. What should happen FIRST?

- (A) Remove the control
- (B) Diagnose whether it is a design or operating issue
- (C) Increase the risk rating
- (D) Cancel audits

Q54: Explanation

Correct Answer: B

- The diagnosis determines the fix
- Design and operating failures need different remedies
- Removing controls may increase exposure

Critical Trap

Diagnose before changing.

Q55: Justified Response

Question

Which condition most strongly justifies mitigation?

- (A) Risk exceeds appetite and a cost-effective control exists
- (B) Risk is low
- (C) Risk has never occurred
- (D) Insurance is available

Q55: Explanation

Correct Answer: A

- Above-appetite risk needs action
- Cost-effectiveness supports the investment
- Low and non-occurring risks do not force mitigation

Critical Trap

Mitigate when above appetite and cost-effective.

Q56: Deficiency Type

Question

A control is well designed but the tool is misconfigured. This is a:

- (A) Design deficiency
- (B) Operating deficiency
- (C) Governance failure
- (D) Scope failure

Q56: Explanation

Correct Answer: B

- Design is sound
- Operation is defective
- Remediation is configuration

Critical Trap

Configuration failures are operating issues.

Q57: Layered Controls

Question

Which combination BEST represents defense in depth?

- A. Multiple controls sharing the same weakness
- B. One control only
- C. Diverse preventive, detective and corrective controls with independent failure modes
- D. Duplicate tools from the same vendor

Q57: Explanation

Correct Answer: C

- Independence reduces common-mode failures
- Diversity matters more than quantity
- Duplicates may share the same flaw

Critical Trap

Layers need independence.

Q58: Control Ownership

Question

Which statement BEST describes control ownership?

- A. The owner is responsible for design, operation and evidence
- B. The owner only pays for the control
- C. The owner audits the control
- D. The owner approves risk appetite

Q58: Explanation

Correct Answer: A

- Ownership includes operation and evidence
- Auditing is independent
- Appetite belongs to leadership

Critical Trap

Control ownership includes operation and evidence.

Q59: Restoration Time

Question

A backup restores data but takes 24 hours against a 4-hour RTO. This is:

- (A) A corrective control that meets its objective
- (B) A corrective control that does not meet the recovery objective
- (C) A preventive control
- (D) A detective control

Q59: Explanation

Correct Answer: B

- Restoration is corrective
- The RTO is missed
- The control is failing a key requirement

Critical Trap

Corrective controls must meet recovery targets.

Q60: Independence

Question

Which tester provides the MOST objective assurance?

- A. The control owner
- B. The project manager
- C. The vendor
- D. An independent assurance function not responsible for the control

Q60: Explanation

Correct Answer: D

- Independence prevents bias
- Responsibility reduces objectivity
- Vendors have commercial interests

Critical Trap

Independence ensures objectivity.

Q61: Gap Handling

Question

A control gap is found. What should be done FIRST?

- A. Report to the board
- B. Assess the exposure caused by the gap
- C. Implement a tool
- D. Change policy

Q61: Explanation

Correct Answer: B

- Exposure determines urgency
- Urgent risks get immediate action
- Lower exposure allows prioritization

Critical Trap

Assess exposure before fixing.

Q62: Automation Risk

Question

Which risk does automation introduce?

A. No risk
B. Consistent operation
C. Silent failure if monitoring is absent
D. Lower cost

Q62: Explanation

Correct Answer: C

- Automated controls can fail silently
- Monitoring is required
- Consistency is a benefit, not a risk

Critical Trap

Automate, but monitor silently.

Q63: Fit to Appetite

Question

How should control selection relate to appetite?

- A. Controls should reduce risk to within appetite at justified cost
- B. Any control is fine
- C. Controls should exceed appetite
- D. Cost is the only factor

Q63: Explanation

Correct Answer: A

- Appetite drives the target level
- Cost must be justified
- Appetite alignment makes controls proportionate

Critical Trap

Match controls to appetite and cost.

Q64: Redundant Controls

Question

Two independent controls cover the same risk. What should the practitioner do?

- A. Remove one immediately
- B. Evaluate whether redundancy supports defense in depth
- C. Ignore both
- D. Increase the risk rating

Q64: Explanation

Correct Answer: B

- Redundancy can be desirable
- Evaluate effectiveness and cost
- Immediate removal may increase exposure

Critical Trap

Justify redundancy, do not assume waste.

Q65: CSA Value

Question

Where does control self-assessment provide the GREATEST value?

- A When owners understand and improve their own controls
- B When there is no external validation
- C When used to replace audits
- D When owners rate themselves highly

Q65: Explanation

Correct Answer: A

- CSA drives ownership and improvement
- External validation adds assurance
- CSA complements audits

Critical Trap

CSA drives ownership and improvement.

Q66: Leading Indicator

Question

Which indicator is most useful as a leading KRI for a ransomware risk?

- **A** Historical ransomware incidents
- **B** Patch latency and backup restore success trends
- **C** Number of unpatched servers last year
- **D** Length of the last downtime

Q66: Explanation

Correct Answer: B

- Patch latency and restore success predict future impact
- Historical incidents are lagging
- Prior-year counts are lagging
- Downtime length is a lagging outcome

Critical Trap

Leading KRIs predict; lagging ones record.

Q67: Signal vs Noise

Question

A KRI routinely alerts during business-critical peak hours. What is the BEST fix?

- (A) Ignore it
- (B) Tune thresholds and correlate with business context
- (C) Disable it
- (D) Increase the risk rating

Q67: Explanation

Correct Answer: B

- Context and thresholds determine false positives
- Tuning improves signal
- Disabling removes warning

Critical Trap

Tune, do not disable.

Q68: Audience Fit

Question

A regulator requests detailed evidence of monitoring. Which report BEST fits?

- (A) A board-level summary
- (B) A concise executive dashboard
- (C) A detailed, evidence-based monitoring report
- (D) A marketing brochure

Q68: Explanation

Correct Answer: C

- Regulators need evidence and detail
- Boards need summaries
- Evidence supports compliance

Critical Trap

Fit the detail to the audience.

Q69: Register Trigger

Question

Which event should NOT automatically trigger a risk register update?

- (A) A significant incident
- (B) A new threat intelligence update relevant to an asset
- (C) A change in the risk owner
- (D) A routine staff birthday

Q69: Explanation

Correct Answer: D

- Incidents change exposures
- Threat updates change likelihood
- Ownership changes affect accountability

Critical Trap

Not everything updates the register.

Q70: Real-Time Alert

Question

Which scenario MOST benefits from real-time monitoring?

- A. Annual compliance reporting
- B. Controls protecting high-value transactions
- C. Long-term strategy reviews
- D. Training attendance

Q70: Explanation

Correct Answer: B

- High-value transactions require timely detection
- Annual and strategic activities are periodic
- Training is monitored periodically

Critical Trap

Real-time where impact is immediate.

Q71: KPI Versus KRI

Question

Which metric is a KPI rather than a KRI?

- **A** Percentage of phishing emails that bypassed filters
- **B** Number of vulnerabilities with active exploits
- **C** Time to respond to incidents against service targets
- **D** Amount of data exposed

Q71: Explanation

Correct Answer: C

- Response time is performance against a target
- Phishing and exploit-based metrics measure risk
- Exposure volume is a risk outcome

Critical Trap

KPIs measure performance against targets.

Q72: Overload

Question

The risk team receives 1,000 alerts per day and responds to none. What is the BEST fix?

- (A) Add more alerts
- (B) Reduce alerts to a prioritized, actionable set with response procedures
- (C) Ignore the alerts
- (D) Turn off the tool

Q72: Explanation

Correct Answer: B

- Prioritization improves response
- Alerts need owners and procedures
- Disabling removes visibility

Critical Trap

Make alerts actionable and prioritized.

Q73: Stable Indicators

Question

All indicators have been stable and green for three years. What is the BEST action?

- (A) Change nothing
- (B) Challenge whether the metrics remain relevant and sensitive
- (C) Reduce the tool budget
- (D) Increase thresholds

Q73: Explanation

Correct Answer: B

- Relevance must be validated over time
- Insensitivity hides risk
- Tuning thresholds upward reduces visibility

Critical Trap

Challenge stable indicators.

Q74: Board Message

Question

Which format BEST conveys risk to the board?

- A. A raw KRI list
- B. A concise view of key exposures against appetite with trends
- C. A technical log
- D. A list of all vulnerabilities

Q74: Explanation

Correct Answer: B

- Boards need decision-level insight
- Appetite and trends guide oversight
- Raw and technical details overwhelm

Critical Trap

Boards need clarity, not detail.

Q75: Missed Signal

Question

A breach occurred but no KRI flagged it. What is the BEST response?

- (A) Ignore it
- (B) Review the monitoring design and consider new or adjusted KRIs
- (C) Blame staff
- (D) Retire the framework

Q75: Explanation

Correct Answer: B

- The framework missed a signal
- Framework improvement is the goal
- Blaming individuals does not improve controls

Critical Trap

Missed signals mean improve the framework.

Q76: Register Reviews

Question

Which cadence BEST supports register accuracy?

- A. Only on incidents
- B. Periodic reviews by owners with risk practitioner facilitation
- C. Never
- D. Only at year-end

Q76: Explanation

Correct Answer: B

- Owners keep entries current
- Periodic reviews catch drift
- Incidents and year-end are triggers but not sufficient alone

Critical Trap

Periodic owner reviews keep registers accurate.

Q77: Escalation Design

Question

What MOST improves the timeliness of risk escalation?

- A. Formal written reports only
- B. Predefined triggers and named escalation recipients
- C. Verbose minutes
- D. Long committee cycles

Q77: Explanation

Correct Answer: B

- Triggers speed action
- Named recipients clarify accountability
- Written-only and long cycles slow escalation

Critical Trap

Predefine triggers and owners.

Q78: KRI Reliability

Question

Which source MOST reduces KRI manipulation risk?

- A. Self-reported metrics only
- B. Automated or independent data feeds
- C. Verbal summaries
- D. Emailed spreadsheets

Q78: Explanation

Correct Answer: B

- Automation reduces manipulation
- Independence strengthens trust
- Verbal and spreadsheet data is harder to verify

Critical Trap

Trust automated or independent data.

Q79: Audit Integration

Question

How should audit findings integrate with risk monitoring?

- (A) They replace KRIs
- (B) They update risks and trigger reassessment where relevant
- (C) They should be ignored
- (D) They are only for compliance reporting

Q79: Explanation

Correct Answer: B

- Findings reveal control weaknesses
- Findings may change likelihood and impact
- They add to, not replace, monitoring

Critical Trap

Audit findings feed the risk process.

Q80: Trend Value

Question

What does an increasing KRI trend below threshold indicate?

- (A) No concern
- (B) Exposure may be rising and may breach threshold soon
- (C) The KRI is wrong
- (D) The risk is eliminated

Q80: Explanation

Correct Answer: B

- Trends can precede breaches
- Early action is possible
- Ignoring trends reduces response time

Critical Trap

Rising trends deserve early action.

Q81: BIA Owner

Question

Which group should OWN the business impact analysis?

- A. IT operations
- B. Internal audit
- C. Business process owners
- D. Vendors

Q81: Explanation

Correct Answer: C

- Business owners understand impact
- IT provides recovery capability
- Auditors provide assurance

Critical Trap

The business owns the BIA.

Q82: RTO Example

Question

Which statement BEST describes an RTO of 6 hours?

- (A) Data can be lost for up to 6 hours
- (B) The process should be restored within 6 hours of disruption
- (C) Downtime is allowed up to 6 hours before consideration of action
- (D) 6 hours is the maximum outage tolerated

Q82: Explanation

Correct Answer: B

- RTO is a recovery target
- Data loss is RPO
- Tolerance limits are separate

Critical Trap

RTO is time to restore.

Q83: RPO Example

Question

Which statement BEST describes an RPO of 1 hour?

- A. Recovery must occur within 1 hour
- B. No more than 1 hour of data can be lost
- C. Backups must run every 24 hours
- D. Downtime can be 1 hour

Q83: Explanation

Correct Answer: B

- RPO is a data loss limit
- Backup frequency should match
- Downtime is RTO

Critical Trap

RPO is data loss tolerance.

Q84: RTO and MTD

Question

Which relationship should hold for a critical system?

- A. RTO greater than MTD
- B. RTO equal to MTD
- C. RTO less than or equal to MTD
- D. No relationship

Q84: Explanation

Correct Answer: C

- Recovery must occur within the tolerable limit
- RTO at or below MTD protects the business
- RTO beyond MTD leaves impact unaddressed

Critical Trap

RTO stays within MTD.

Q85: BIA Prioritization

Question

Which criterion BEST drives BIA prioritization?

- A. Number of users
- B. Cost of the system
- C. Business and financial impact over time
- D. Vendor preference

Q85: Explanation

Correct Answer: C

- Impact drives priorities
- Users and cost are inputs but not primary
- Vendors are not the business

Critical Trap

Impact over time determines priority.

Q86: Backup Gap

Question

RPO is 4 hours; nightly backups run at midnight. What is the exposure?

- A Up to 4 hours of data loss
- B Up to 24 hours of data loss
- C No data loss
- D Up to 1 hour of data loss

Q86: Explanation

Correct Answer: B

- Nightly backups allow up to 24 hours of loss
- The RPO is exceeded
- Backup design must change

Critical Trap

Match backup cadence to RPO.

Q87: DR Validation

Question

A DR test reveals a 10-hour restore against a 4-hour RTO. What should be done NEXT?

- (A) Accept the result
- (B) Identify causes, update the plan and retest
- (C) Raise the RTO automatically
- (D) Cancel the test

Q87: Explanation

Correct Answer: B

- RTO misses must be addressed
- Root causes and retests improve confidence
- Unilateral RTO change needs business approval

Critical Trap

Fix and retest, do not ignore.

Q88: Vendor Risk Timing

Question

When should a third party be evaluated for the FIRST time?

- (A) After an incident
- (B) During contract negotiation and before onboarding
- (C) Only at renewal
- (D) Never

Q88: Explanation

Correct Answer: B

- Pre-contract evaluation shapes terms
- Negotiation enables controls
- Onboarding without evaluation increases exposure

Critical Trap

Evaluate before onboarding.

Q89: Contract Controls

Question

Which contract clause MOST supports ongoing third-party risk oversight?

- (A) A pricing clause
- (B) Right-to-audit and assurance reporting duties
- (C) Logo usage
- (D) Coffee supply at meetings

Q89: Explanation

Correct Answer: B

- Oversight needs access to evidence
- Reporting duties provide ongoing visibility
- Commercial items do not address risk

Critical Trap

Oversight depends on contract rights.

Q90: Concentration

Question

An organization relies on one cloud provider for all critical services. What is the BEST action?

- (A) Increase reliance
- (B) Assess concentration risk and develop contingency or exit strategy
- (C) Ignore it
- (D) Cancel the contract

Q90: Explanation

Correct Answer: B

- Concentration is a risk
- Contingency reduces impact
- Ignoring the risk understates exposure

Critical Trap

Concentration needs an exit plan.

Q91: Register Content

Question

Which entry set is MINIMUM for a credible risk register entry?

- **A** Owner, risk statement, rating, response, review date
- **B** Contact phone number and budget code
- **C** Marketing description
- **D** Vendor name only

Q91: Explanation

Correct Answer: A

- Owners, statements and ratings enable management
- Review dates keep entries fresh
- Extraneous fields add noise

Critical Trap

Core fields enable governance.

Q92: Owner Authority

Question

A risk owner lacks the authority to approve needed spending. What should happen?

- **A** Approve without authority
- **B** Realign ownership with someone who has the authority
- **C** Ignore the risk
- **D** Lower the rating

Q92: Explanation

Correct Answer: B

- Ownership requires authority
- Misalignment causes ineffective action
- Ratings must not be manipulated

Critical Trap

Ownership requires the ability to act.

Q93: Tone at the Top

Question

Which action MOST signals a strong risk culture?

- A Leaders acknowledge risks and act on them
- B Frequent communications only
- C Detailed dashboards only
- D Annual celebrations

Q93: Explanation

Correct Answer: A

- Leadership behavior drives culture
- Communication and dashboards support, but do not replace, behavior
- Celebrations do not change behavior

Critical Trap

Behaviors shape culture.

Q94: Line Roles

Question

In the three lines model, who provides independent assurance?

- (A) The first line
- (B) The second line
- (C) The third line (internal audit)
- (D) External vendors

Q94: Explanation

Correct Answer: C

- First line owns risk
- Second line oversees and advises
- Third line provides independent assurance

Critical Trap

Independence sits in the third line.

Q95: Practitioner Behavior

Question

Which action BEST reflects the risk practitioner's independence?

- A. Approving the risk acceptance
- B. Advising the owner while avoiding the decision
- C. Choosing the vendor
- D. Operating the control

Q95: Explanation

Correct Answer: B

- Independence means advising, not deciding
- Choosing vendors or operating controls reduces independence
- Owners decide

Critical Trap

Advise without deciding.

Q96: Emerging Tech

Question

Before adopting a new technology, which governance step is MOST important?

- A. A pilot without assessment
- B. A proportionate risk assessment and ownership decision
- C. Immediate production rollout
- D. Waiting for incidents

Q96: Explanation

Correct Answer: B

- Assessment informs decisions
- Proportionality keeps adoption practical
- Unassessed rollout increases exposure

Critical Trap

Assess before adoption.

Q97: Frequency

Question

Which combination BEST defines risk assessment frequency?

- A. Annual only
- B. On incidents only
- C. Periodically and on significant change
- D. Only at project end

Q97: Explanation

Correct Answer: C

- Periodic reviews catch drift
- Significant changes create new risks
- Annual is a minimum, not sufficient alone

Critical Trap

Periodic plus change-driven assessments.

Q98: Executive Language

Question

Which phrase BEST supports executive decision-making?

- (A) Three CVEs have a CVSS score above 9
- (B) The payment process has a 30% chance of extended outage within twelve months
- (C) Patches were deployed to VLAN 12
- (D) The SIEM correlates logs by rule set

Q98: Explanation

Correct Answer: B

- Executives need business impact and likelihood
- Vulnerability and configuration detail belong to specialists
- Business-oriented language drives action

Critical Trap

Speak in business consequences.

Q99: Stale Entries

Question

An owner has not reviewed their register entries for two years. What is the BEST response?

- A. Escalate stale entries and reset a review cadence
- B. Remove the owner
- C. Ignore them
- D. Increase ratings

Q99: Explanation

Correct Answer: A

- Stale entries may be wrong
- Escalation encourages ownership
- A cadence prevents drift

Critical Trap

Stale registers misinform.

Q100: Owner Assigned

Question

A new risk has no owner. What should the practitioner do?

- (A) Assign it to IT
- (B) Escalate to leadership to assign an accountable owner
- (C) Leave it unowned
- (D) Close it

Q100: Explanation

Correct Answer: B

- Ownership must reflect accountability
- Leadership assigns owners
- Defaulting to IT misaligns accountability

Critical Trap

Unowned risks are unmanaged.

Exam Mindset Summary

Remember

- **FIRST:** understand context and assess before acting
- **Owners decide:** business owners accept risk; the practitioner advises
- **Appetite:** compare residual risk to appetite, then escalate or treat
- **Accountability** cannot be outsourced or transferred
- **Monitor:** validate data, trend it, and keep the register current

Good Luck on Your CRISC Exam!